

Manual 26 — Incident Response & Cyber Crisis Management Controlled Implementation

Source baseline: NIST SP 800-61 Rev. 3 (final, April 2025) supersedes Rev. 2 and aligns incident response with CSF 2.0. CISA and jurisdiction-specific notification guidance are supporting/overlay sources and must not be treated as universally binding. Recheck current source state before release.

01. Purpose, scope, and assurance boundary

Define a practical incident-response and cyber-crisis operating model without implying universal legal sufficiency, breach reportability, or audit opinion.

02. Source hierarchy and version control

Separate NIST guidance, CISA guidance, regulatory notification rules, contractual obligations, sector overlays, insurer requirements, and internal policy.

03. Governance and executive accountability

Assign executive sponsor, incident commander, crisis leader, legal/privacy roles, communications authority, business owners, and evidence accountability.

04. Incident response policy

Define policy scope, authority, severity thresholds, escalation, evidence, communications, recovery, lessons learned, and governance requirements.

05. Organizational preparation

Maintain readiness across people, process, tooling, logging, contact data, access, backups, forensic capability, vendors, and decision support.

06. Asset, service, and dependency context

Link incident response to critical services, assets, identities, applications, cloud services, suppliers, facilities, and business processes.

07. Threat and scenario planning

Maintain scenario libraries for ransomware, data theft, account compromise, cloud abuse, supply-chain events, destructive malware, insider misuse, and service disruption.

08. Detection and event intake

Define monitored sources, alert triage, user/vendor reporting, escalation channels, minimum intake data, and evidence preservation.

09. Triage and initial analysis

Assess credibility, scope, affected services, indicators, likely impact, uncertainty, and immediate containment needs.

10. Incident declaration and severity

Use documented declaration criteria and severity levels tied to impact, spread, legal/regulatory triggers, customer harm, safety, and executive attention.

11. Incident command structure

Define operational command, specialist workstreams, decision authority, handoffs, battle rhythm, and command-log requirements.

12. Crisis-management integration

Escalate from incident handling to enterprise crisis governance when business, legal, safety, reputational, geopolitical, or executive thresholds are met.

13. Investigation and evidence preservation

Preserve logs, images, artifacts, timelines, chain-of-custody records, analyst notes, and decision evidence proportionate to legal and operational needs.

14. Containment strategy

Select short- and long-term containment actions using impact, attacker persistence, business criticality, safety, customer harm, and recovery constraints.

15. Eradication and root-cause analysis

Remove malicious presence, correct exploited weaknesses, invalidate compromised credentials, remediate persistence, and document causal factors.

16. Recovery planning

Define restoration order, clean-state criteria, security validation, business-owner acceptance, monitoring, rollback, and residual-risk decisions.

17. Identity and access recovery

Address credential reset, token revocation, privileged access, break-glass controls, federation, service accounts, and identity-provider compromise.

18. Ransomware and extortion response

Define decision governance for encryption, data theft, extortion, law enforcement, insurer, legal, communications, restoration, and sanctions-related review without prescribing payment decisions.

19. Data breach and privacy incident coordination

Coordinate privacy, legal, security, records, customer, regulator, and jurisdiction-specific assessment while preserving distinct reportability tests.

20. Regulatory and contractual notification

Maintain a jurisdiction- and obligation-aware notification matrix with trigger, timing, authority, owner, content, evidence, and change-control fields.

21. Third-party and supply-chain incidents

Define supplier notification, evidence, containment coordination, alternate service, contractual escalation, assurance, and concentration-risk response.

22. Cloud and SaaS incidents

Address shared responsibility, provider logs, tenant isolation, identity, API abuse, region impacts, evidence access, provider escalation, and recovery dependencies.

23. OT/ICS and safety-sensitive incidents

Preserve safety, reliability, engineering authority, process constraints, evidence, vendor coordination, and sector-specific escalation over purely IT-centric actions.

24. Communications and stakeholder management

Define internal communications, customer notices, media response, spokesperson authority, message approval, rumor control, and executive briefings.

25. Decision logging and crisis records

Maintain time-stamped decisions, assumptions, evidence considered, approvers, alternatives, residual risks, and follow-up actions.

26. Legal privilege and investigation boundaries

Coordinate counsel-led decisions where appropriate without assuming privilege automatically applies; separate operational facts from legal conclusions.

27. Business continuity and disaster recovery integration

Link incident response to BCMS activation, disaster recovery, alternate operations, supplier continuity, and crisis-management thresholds.

28. Exercises and simulations

Run tabletop, technical, executive, supplier, ransomware, cloud, communications, and integrated crisis exercises with measurable objectives.

29. Metrics and performance management

Track detection, declaration, containment, eradication, recovery, recurrence, exercise findings, notification readiness, issue aging, and evidence completeness.

30. Post-incident review and remediation

Perform lessons learned, root-cause validation, control-gap analysis, action tracking, residual-risk acceptance, and closure verification.

31. Assurance and management review

Provide independent review and leadership oversight over readiness, incidents, exercises, metrics, findings, resources, and improvement priorities.

32. Release, evidence, and implementation roadmap

Package Essential / Structured / Enhanced implementation paths with source verification, localization, accessibility, provenance, checksums, workflow-security, exact candidate identity, and sequential release controls.